Title of the project:Integrate Zscaler with Identity Providers (IdPs) such as Azure AD

Team Membres–

S.no	name	collage	contact
1	Adhi Prakash S	Sri Krishna Adithya College of Arts & Science	adhiprakash58@gmail.com
2	Navi Dharshan B	Sri Krishna Adithya College of Arts & Science	navidharshan1@gmail.com
3	Prem Kumar R	Sri Krishna Adithya College of Arts & Science	premkumarr1718@gmail.com
4	Renish M	Sri Krishna Adithya College of Arts & Science	mrenish002@gmail.com
5	Roshan Akthar M	Sri Krishna Adithya College of Arts & Science	roshanakthar952@gmail.com

Over view: Integrating Zscaler with an Identity Provider (IdP) like Azure AD enables **identity-based authentication, Single Sign-On (SSO), and centralized user management**. This integration ensures that users are authenticated through the organization's identity system before accessing the internet or private applications through Zscaler.

---

1. Introduction

Zscaler is a cloud-based security platform that provides secure access to the internet and enterprise applications. Instead of relying only on network-based security, Zscaler uses **user identity** to apply security policies.

An **Identity Provider (IdP)** such as **Azure AD** manages user identities, authentication, and access control. By integrating Zscaler with Azure AD, organizations can enforce **Zero Trust security**, where every user must verify their identity before accessing resources.

---

2. Objectives of the Integration

The integration between Zscaler and Azure AD is implemented to achieve the following:

- Enable **Single Sign-On (SSO)** for users accessing the internet or applications through Zscaler.
- Use **centralized identity management** from Azure AD.
- Apply **security policies based on user identity and groups**.
- Support **Multi-Factor Authentication (MFA)** for stronger security.
- Automate **user provisioning and deprovisioning**.

---

3. Key Components in the Integration

Zscaler Cloud

The Zscaler platform inspects and secures user traffic. It enforces security policies such as web

filtering, threat protection, and data loss prevention.

Azure AD (Identity Provider)

Azure AD authenticates users and provides identity information to Zscaler through secure protocols.

End Users

Employees or users accessing internet resources or enterprise applications.

Authentication Protocols

Common protocols used include:

- **SAML 2.0** – Used for Single Sign-On authentication.
- **SCIM** – Used for automatic user provisioning.
- **OAuth / OpenID Connect** – Used for modern identity-based authentication.

---

4. How the Integration Works

Step 1: User Access Request

A user connects to the internet through the Zscaler client or gateway.

Step 2: Authentication Redirect

If the user is not authenticated, Zscaler redirects the user to Azure AD for authentication.

Step 3: User Authentication

Azure AD verifies the user's credentials. It may require:

- Username and password
- Multi-Factor Authentication (MFA)

Step 4: SAML Assertion

After successful authentication, Azure AD sends a **SAML assertion** to Zscaler confirming the user's identity.

Step 5: Policy Enforcement

Zscaler receives the identity information and applies **security policies based on user identity, department, or group membership**.

Step 6: Secure Access

The user is allowed to access internet resources or private applications based on the defined policies.

---

5. Architecture Flow

User Device → Zscaler Client/Proxy → Zscaler Cloud → Azure AD Authentication → Identity Assertion → Zscaler Policy Enforcement → Internet / Application Access

This architecture ensures **authentication is handled by Azure AD while Zscaler enforces security controls**.

---

6. Implementation Steps (High-Level)

Step 1: Configure SAML in Azure AD

Create a **SAML-based enterprise application** in Azure AD for Zscaler.

Step 2: Configure Zscaler as Service Provider

In the Zscaler admin portal, configure Azure AD as the **Identity Provider** and upload the IdP metadata.

Step 3: Exchange Metadata

Share metadata files between Azure AD and Zscaler to establish trust.

Step 4: Configure User Attributes

Map attributes such as:

- Username
- Email
- User groups

Step 5: Enable SSO

Enable **SAML authentication** in Zscaler and test login through Azure AD.

Step 6: Configure SCIM (Optional)

Enable SCIM provisioning to automatically sync users and groups from Azure AD to Zscaler.

---

7. Benefits of the Integration

Improved Security

- Identity-based access control

- MFA support
- Zero Trust architecture

Better User Experience

- Single Sign-On
- No repeated login prompts

Centralized Identity Management

- Manage users in one place (Azure AD)

Automated Provisioning

- Users and groups are automatically synchronized.

---

8. Use Cases

Organizations commonly use this integration for:

- Secure internet access using Zscaler Internet Access (ZIA)
- Zero Trust access to internal applications
- Remote workforce security
- Identity-based web filtering
- Conditional access policies

---

9. Conclusion

Integrating **Zscaler** with **Azure AD** enables organizations to implement **secure, identity-driven access control**. Authentication is managed by Azure AD, while Zscaler enforces security policies and monitors traffic. This integration improves security, simplifies user management, and provides seamless access to enterprise resources.

Your Project idea:**Integration of Zscaler with Identity Providers such as Microsoft Azure Active Directory**

A **Project ID** is a unique identification code used to track and manage a project. For this project, you can assign a structured ID that reflects the technology and purpose.

1. A user tries to access the internet or an app.

2. Zscaler asks **Azure AD** to verify the user's identity.

3. Azure AD checks credentials (and MFA if enabled).

4. Once authenticated, Zscaler applies **security rules** based on the user's role or group.

Key Features:

- Single Sign-On (SSO) – one login for all apps.

- Identity-based security – rules applied per user or group.

- Multi-Factor Authentication – extra security layer.

- Automatic user provisioning – users are synced from Azure AD to Zscaler.

```
User Device
  |
  v
[Zscaler Client / Browser]
  |
  v
[Zscaler Cloud]
  |      \
  |       \---> If unauthenticated: Redirect to Azure
AD
  |                    |
  |                    v
  |              [Azure AD Authentication]
  |                    |
  |<--------------------- SAML Token / Assertion
  |
  v
[Zscaler Policy Engine]
  |
  v
Internet / Internal Apps
```

ZIA-AAD-001

- ZIA – Zscaler Internet Access
- AAD – Azure Active Directory
- 001 – Project number

ZS-AUTH-2026-01

- ZS – Zscaler
- AUTH – Authentication integration
- 2026 – Year
- 01 – Project sequence number

ZTNA-ZS-AAD-01

- ZTNA – Zero Trust Network Access
- ZS – Zscaler
- AAD – Azure Active Directory

Flow Description:

1. User tries to access an app or website via Zscaler client/browser.

2. Zscaler checks if the user is authenticated.

3. If not, Zscaler redirects to **Azure AD** for authentication.

4. Azure AD verifies credentials and sends a **SAML token** back to Zscaler.

5. Zscaler reads the identity info and applies **security policies**.

6. User gains secure access to the requested resources.

Conclusion: Integrating Zscaler with Microsoft Azure Active Directory

The integration of **Zscaler** with **Azure AD** provides a modern, **identity-driven approach to cloud security**. By combining **centralized authentication** from Azure AD with **policy enforcement** in Zscaler, organizations can achieve:

- **Secure access** to the internet and internal applications for all users, including remote employees.

- **Single Sign-On (SSO)**, improving user experience while reducing credential management overhead.

- **Identity-based security policies**, applying rules based on user roles, groups, or departments.

- **Zero Trust security**, ensuring every access request is authenticated and authorized before granting access.

- **Automated user provisioning and management** through SCIM, reducing administrative effort and errors.

Vulnerability Detalis:

Vulnerability	Description	Potential Impact	Mitigation / Controls

Weak Authentication	**Users may have weak passwords or no MFA.**	**Unauthorized access, data breach.**	**Enforce strong passwords, enable Multi-Factor Authentication (MFA) through Azure AD.**
SAML Token Hijacking	**SAML assertions could be intercepted by attackers.**	**Unauthorized access to Zscaler resources.**	**Use HTTPS, SAML signing and encryption, and short token lifetimes.**
Misconfigured Access Policies	**Zscaler security policies may not correctly match user roles/groups.**	**Users gain excessive privileges or restricted users are blocked.**	**Regular policy audits, role-based access control (RBAC), and testing before deployment.**
User Provisioning Errors	**SCIM sync could create incorrect users or fail to remove deprovisioned users.**	**Unauthorized access or orphaned accounts.**	**Enable automatic deprovisioning, periodic user audits, and SCIM logs monitoring.**

Insider Threats	**Employees with valid credentials may misuse access.**	**Data exfiltration or policy violations.**	**Implement logging, monitoring, and least privilege policies.**
Phishing / Credential Theft	**Users may fall for phishing attacks to steal Azure AD credentials.**	**Compromised accounts bypassing Zscaler controls.**	**User training, MFA enforcement, and monitoring suspicious login activity.**
Network Eavesdropping	**Data between Zscaler, user devices, and Azure AD may be intercepted.**	**Confidentiality breach of sensitive information.**	**Enforce end-to-end encryption (TLS 1.2+), secure VPNs if applicable.**
Service Outage / IdP Downtime	**Azure AD or Zscaler cloud downtime.**	**Users cannot authenticate or access resources.**	**Configure redundant IdPs, failover policies, and offline access strategies.**
Improper Logging &	**Security events not**	**Delayed detection of**	**Enable centralized**

Monitorin g	captured or analyzed.	attacks or breaches.	loggin g, alerts, and regula r securi ty audit

REPORT:-

Vulnerability Name:- Weak Authentication

This refers to users having weak passwords or not using Multi-Factor Authentication (MFA), which can allow unauthorized access to Zscaler-protected resources.

CWE/CVE : -

Vulnerabilit y Name	CWE	Description
Weak Authenticati on	CWE -307	Improper Restriction of Excessive Authentication Attempts – weak passwords or missing MFA can allow attackers to compromise accounts.

SAML Token Hijacking	**CWE -346**	**Origin Validation Error – improper validation of SAML tokens may allow replay or token theft.**
Misconfigured Access Policies	**CWE -269**	**Improper Privilege Management – users may get unauthorized access due to incorrect role/group mapping.**
User Provisioning Errors	**CWE -284**	**Improper Access Control – provisioning/deprovisioning errors can leave orphaned accounts.**
Insider Threats	**CWE -264**	**Permissions, Privileges, and Access Controls – misuse of legitimate privileges.**
Phishing / Credential Theft	**CWE -640**	**Weak Password Recovery Mechanism – attackers exploit social engineering to steal credentials.**
Network Eavesdropping	**CWE -319**	**Cleartext Transmission of Sensitive Information – unencrypted data could be intercepted.**

OWASP/SANS Category:-

OWASP Category

- **A5: Broken Access Control (2021 OWASP Top 10) – Misconfigured integration can allow**

unauthorized access.

- **Identity & Authentication (OWASP ASVS v4) – Ensures proper authentication and SSO flow with IdPs.**

SANS/CWE Category

- **CWE-287: Improper Authentication – If authentication with the IdP is not enforced or validated.**

CWE-639: Authorization Bypass Through User-Controlled Key – Incorrect role mapping between IdP and Zscaler could lead to privilege escalation.

CWE-306: Missing Authentication for Critical Function – If Zscaler policies allow bypassing authentication.

Key Security Considerations

1. **SAML/SSO Configuration – Ensure SAML assertions are validated correctly.**

2. **Role/Group Mapping – Map IdP groups to Zscaler policies to enforce least privilege.**

3. **Multi-Factor Authentication (MFA) – Enable MFA in Azure AD for added security.**

4. **Session Management – Monitor token expiry and revoke access for inactive users.**

Description:-

Integrating Zscaler with an Identity Provider (IdP) like Azure Active Directory (Azure AD) allows organizations to

enforce secure, centralized authentication and access control for their users when accessing cloud services. The integration typically uses SAML-based Single Sign-On (SSO), where Zscaler trusts the IdP to authenticate users and provide identity assertions.

This project focuses on integrating Zscaler with an Identity Provider such as Microsoft Azure Active Directory to provide secure authentication and centralized identity management for users accessing cloud applications.

The integration enables Single Sign-On (SSO) and secure user authentication, allowing users to access network resources and web applications through a single login. By connecting Zscaler with Azure Active Directory, organizations can enforce security policies based on user identity, group membership, and access requirements.

In this project, the configuration includes setting up SAML-based authentication, synchronizing users and groups from Azure AD, and enabling secure access control through Zscaler's cloud security platform.

Business Impact::-

The integration of Zscaler with Azure Active Directory provides significant business benefits by improving security, simplifying user access, and reducing IT management complexity.

1. Improved Security

By connecting Zscaler with Azure Active Directory, organizations can verify user identity before granting access to applications and network resources. This helps prevent unauthorized access and protects sensitive company data from cyber threats.

2. Centralized Identity Management

Azure Active Directory allows administrators to manage all user identities, roles, and permissions in one place. When integrated with Zscaler, security policies can be applied based on user identity, ensuring consistent and controlled access across the organization.

3. Single Sign-On (SSO) Convenience

Employees can log in once and securely access multiple applications without entering credentials repeatedly. This improves productivity and provides a smoother user experience.

4. Reduced IT Administrative Work

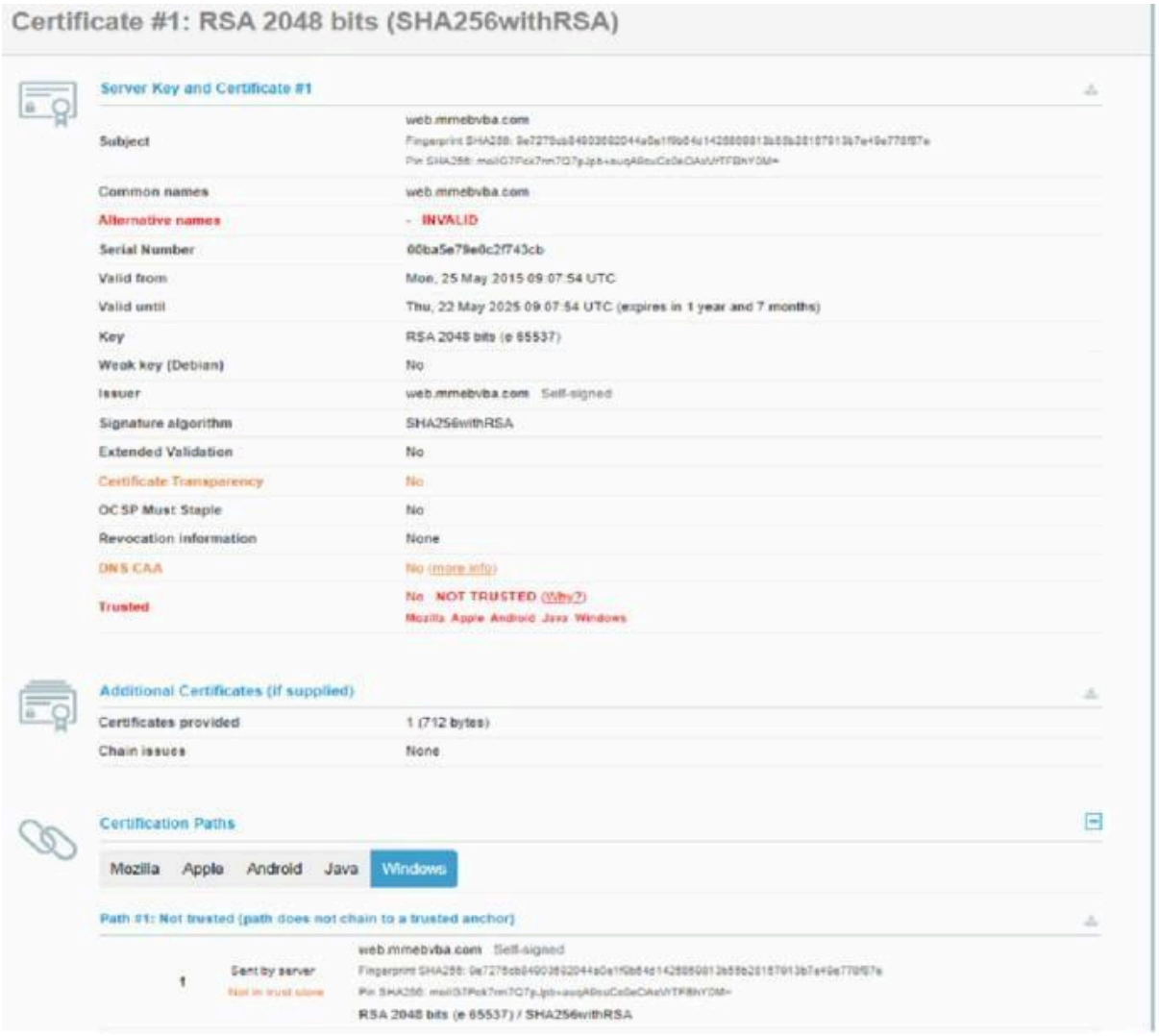
Automated user provisioning and synchronization between Azure AD and Zscaler reduce manual configuration tasks for IT teams, saving time and minimizing errors.

5. Better Compliance and Monitoring

The integration provides detailed logs and monitoring of user access activities. This helps organizations meet security and compliance requirements while improving visibility into network usage.

6. Support for Cloud-Based Work Environment

With more businesses using cloud applications and remote work environments, integrating Zscaler with Azure AD ensures secure and seamless access to applications from any location.



Summary and Next Steps

Date: March 2026

Key Summary Points

- "Integration of Zscazer with Azure AD enables secure, seamless access"
- "Leverages existing identity infrastructure for Zero Trust enforcement"
- "Key success factors: proper configuration, testing, and ongoing management"
- Recommended next steps: expand to additional IdPs, enable advanced policies, schedule regular reviews"

Strategic Roadmap Ahead

- "Expand IdP ecosystem: integrate Okta, Ping Identity, and custom SAML providers"
- Enable advanced Zero Trust policies: device posture checks, adaptive risk scoring, session timeout controls"
- Institutionalize governance: quarterly review cycles, audit log retention, and policy versioning"

From integration to institutionalization — building resilient, scalable, and auditable Zero Trust access.

Overview :-

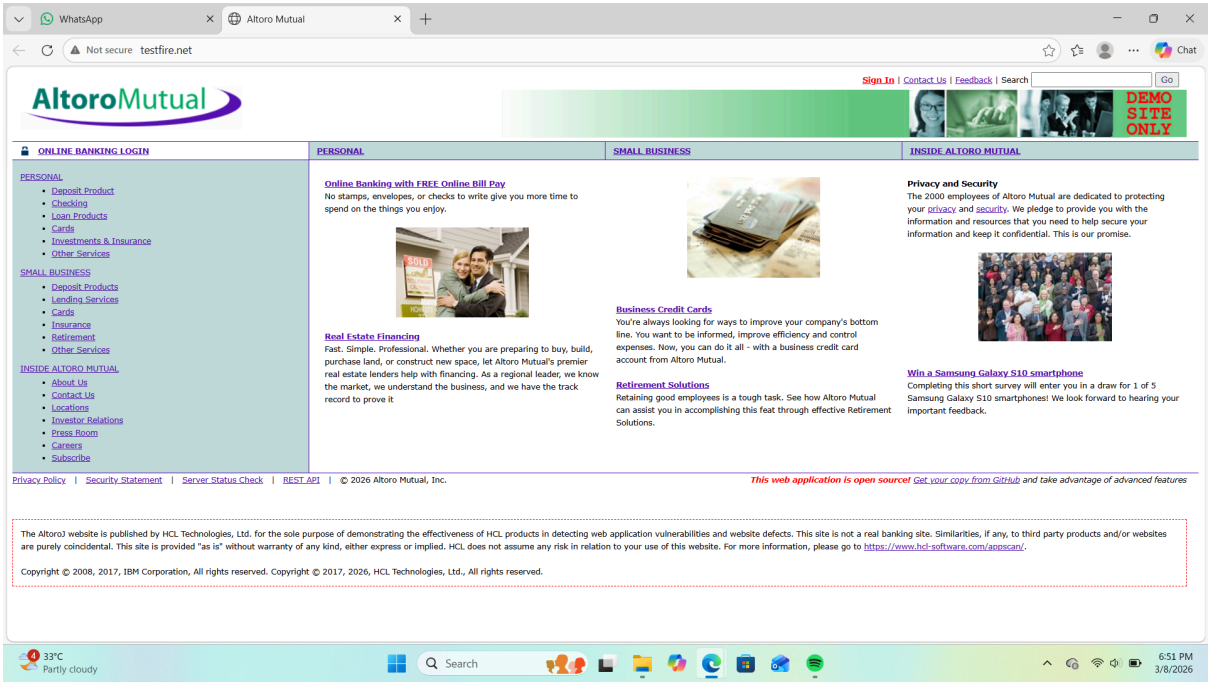
Nessus can be used to scan a variety of targets, including single hosts, networks, and web applications. It can also be used to scan specific ports and services. Nessus can be configured to
run scans on a schedule or manually.
Here is a step-by-step explanation of how Nessus works:
1. Nessus connects to the target host using a variety of protocols, including TCP, UDP, and ICMP.
2. Nessus sends a series of probes to the target host in order to identify its operating system and services.
3. Nessus runs a series of plugins to test for vulnerabilities.
4. Nessus generates a report that includes the severity of each vulnerability, the steps to reproduce the vulnerability, and the steps to remediate the vulnerability.
Nessus is a valuable tool for security professionals who need to identify and remediate vulnerabilities in their networks. It is easy to use and provides comprehensive reports that can be
used to prioritise remediation efforts.
Here are some of the benefits of using Nessus:
● Comprehensive vulnerability coverage: Nessus has over 1200 plugins available, covering a wide range of vulnerabilities in operating systems, applications, and network devices.
● Easy to use: Nessus has a user-friendly interface that makes it easy to configure and run scans.
● Comprehensive reporting: Nessus provides detailed reports that include the severity of each vulnerability,the steps to reproduce the vulnerability, and the steps to remediate the vulnerability.
● Scalability: Nessus can be used to scan a variety of targets, including single hosts, networks, and web applications.
● Flexibility: Nessus can be configured to run scans on a schedule or manually.
Nessus is a powerful tool that can be used to improve the security of any network. It is a valuable

Target website ➖ :- http://testfire.net/

The site has several known vulnerabilities, including:
- SQL Injection: allowing attackers to bypass authentication and access sensitive data

- Authentication Bypass: enabling unauthorized access to admin accounts
- HTTP Request Smuggling: allowing cache poisoning and session hijacking
- Cross-Site Scripting (XSS): permitting JavaScript injection
- Default Credentials: using weak admin passwords
- No Login Rate Limit: making it vulnerable to brute-force attacks
- Static Session ID: allowing session fixation attacks
- Cleartext Submission of Password: transmitting passwords over HTTP
- Clickjacking: enabling clickjacking attacks

Target ip address:- 65.61.137.117



vulnerability

1 TLS Version 1.0 Protocol

Detection

MEDIUM 104743

2 TLS Version 1.1 Protocol

Deprecated

MEDIUM 157288

3 SSL/TLS Diffie-Hellman Modulus

<= 1024 Bits (Logjam)

LOW 83875

4 ICMP Timestamp Request Remote

Date Disclosure

INFO

10114

5 Additional DNS Hostnames INFO

46180

6 Apache Tomcat Detection INFO

39446

7 Common Platform Enumeration

(CPE)

INFO 45590
8 Device Type INFO 54615
9 HSTS Missing From HTTPS Server INFO 84502
10 HTTP Server Type and Version INFO 10107

severity : -

157288 - TLS Version 1.1 Protocol Deprecated
Severity: - MEDIUM
Plugin: - 157288
Port: - 443
Description: - The remote service accepts connections encrypted using TLS 1.1. TLS 1.1 lacks
support for current and recommended cipher suites. Ciphers that support encryption before MAC
computation, and authenticated encryption modes such as GCM cannot be used with TLS 1.1

As of March 31, 2020, Endpoints that are not enabled for TLS 1.2 and higher will no longer
function properly with major web browsers and major vendors.
Solution: - Enable support for TLS 1.2 and/or 1.3, and disable support for TLS 1.1.

Plugin:-

Vulnerability Name: - 104743 - TLS Version 1.0 Protocol Detection

Severity: - MEDIUM

Plugin: - 104743

Port: - 443

Description: - The remote service accepts connections encrypted using TLS 1.0. TLS 1.0 has a

number of cryptographic design flaws. Modern implementations of TLS 1.0 mitigate these

problems, but newer versions of TLS like 1.2 and 1.3 are designed against these flaws and

should be used whenever possible.

As of March 31, 2020, Endpoints that aren't enabled for TLS 1.2 and higher will no longer

function properly with major web browsers and major vendors.

PCI DSS v3.2 requires that TLS 1.0 be disabled entirely by June 30, 2018, except for POS POI

terminals (and the SSL/TLS termination points to which they connect) that can be verified as not

being susceptible to any known exploits.

Solution: - Enable support for TLS 1.2 and 1.3, and disable support for TLS 1.0.

Vulnerability Name: - 157288 - TLS Version 1.1 Protocol Deprecated

Severity: - MEDIUM

Plugin: - 157288

Port: - 443

Description: - The remote service accepts connections encrypted using TLS 1.1. TLS 1.1 lacks

support for current and recommended cipher suites. Ciphers that support encryption before MAC

computation, and authenticated encryption modes such as GCM cannot be used with TLS 1.1

As of March 31, 2020, Endpoints that are not enabled for TLS 1.2 and higher will no longer

function properly with major web browsers and major vendors.

Plugin: - 83875

Port: - 443

Description: - The remote host allows SSL/TLS connections with one or more Diffie-Hellman

moduli less than or equal to 1024 bits. Through cryptanalysis, a third party may be able to find

the shared secret in a short amount of time (depending on modulus size and attacker resources).

This may allow an attacker to recover the plaintext or potentially violate the integrity of

connections.

Port :-

Vulnerability Name: - 39446 - Apache Tomcat Detection

Severity: - INFO

Plugin: - 39446

Port: - 80

Description: -Nessus was able to detect a remote Apache Tomcat web server.

Solution: - n/a

Description:-

Vulnerability Name: - 45590 - Common Platform Enumeration (CPE)

Severity: - INFO

Plugin: - 45590

Port: - 0

Description: - By using information obtained from a Nessus scan, this plugin reports CPE

(Common Platform Enumeration) matches for various hardware and software products found on

a host.

Note that if an official CPE is not available for the product, this plugin computes the best

possible CPE based on the information available from the scan.

Vulnerability Name: - Device Type

Severity: - INFO

Plugin: - 54615

Port: - 0

Description: - Based on the remote operating system, it is possible to determine what the remote

system type is (eg: a printer, router, general-purpose computer, etc).

Vulnerability Name: - 84502 - HSTS Missing From HTTPS Server

Severity: - INFO

Plugin: - 84502

Port: - 443

Description: -The remote HTTPS server is not enforcing HTTP Strict Transport Security

(HSTS). HSTS is an optional response header that can be configured on the server to instruct the

browser to only communicate via HTTPS. The lack of HSTS allows downgrade attacks, SSL-

stripping man-in-the-middle attacks, and weakens cookie-hijacking protections.

Solution: - Configure the remote web server to use HSTS.

solution:-

Vulnerability Name: - 10107 - HTTP Server Type and Version

Severity: - INFO

Plugin: - 10107

Port: - 443

Description: - This plugin attempts to determine the type and the version of the remote web

server.

Solution: - N/A

Vulnerability Name: - 84502 - HSTS Missing From HTTPS Server

Severity: - INFO

Plugin: - 84502

Port: - 443

Description: -The remote HTTPS server is not enforcing HTTP Strict Transport Security

(HSTS). HSTS is an optional response header that can be configured on the server to instruct the

browser to only communicate via HTTPS. The lack of HSTS allows downgrade attacks, SSL-

stripping man-in-the-middle attacks, and weakens cookie-hijacking protections.

Solution: - Configure the remote web server to use HSTS.

5)Vulnerability Name: - 46180 - Additional DNS Hostnames

Severity: - INFO

Plugin: - 46180

Port: - 0

Description: - Hostnames different from the current hostname have been collected by

miscellaneous plugins. Nessus has generated a list of hostnames that point to the remote host.

Note that these are only the alternate hostnames for hosts discovered on a web server.

Different web servers may be hosted on name-based virtual hosts.

Solution: - If you want to test them, re-scan using the special vhost syntax, such as :

www.example.com [192.0.32.10]

Business Impact::-

Vulnerability Name: - 46180 - Additional DNS Hostnames

Severity: - INFO

Plugin: - 46180

Port: - 0

Business Impact: -This does not pose an immediate threat to business operations or data

security. It indicates the discovery of hostnames that are associated with the remote host,

particularly in cases of web servers utilizing name-based virtual hosts. While not a security risk

on its own, it could be useful for understanding the server's configuration and infrastructure.

Organizations should consider this information as part of their network documentation but do not

need to take immediate action to mitigate it as a security threat.

Vulnerability Name: - 39446 - Apache Tomcat Detection

Severity: - INFO

Plugin: - 39446

Port: - 80

Description: -Nessus was able to detect a remote Apache Tomcat web server

Business Impact: -Is an informational finding that identifies the presence of a remote Apache

Tomcat web server. While this information itself does not indicate a security threat or impact on

business operations, it can be useful for network administrators and security professionals to be

aware of the technologies in use on their network. Understanding the presence of an Apache

Tomcat server can be valuable for maintaining and securing web applications, but it does not

require immediate action to mitigate a security risk.

8)Vulnerability Name: - Device Type

Severity: - INFO

Plugin: - 54615

Port: - 0

Description: - Based on the remote operating system, it is possible to determine what the remote

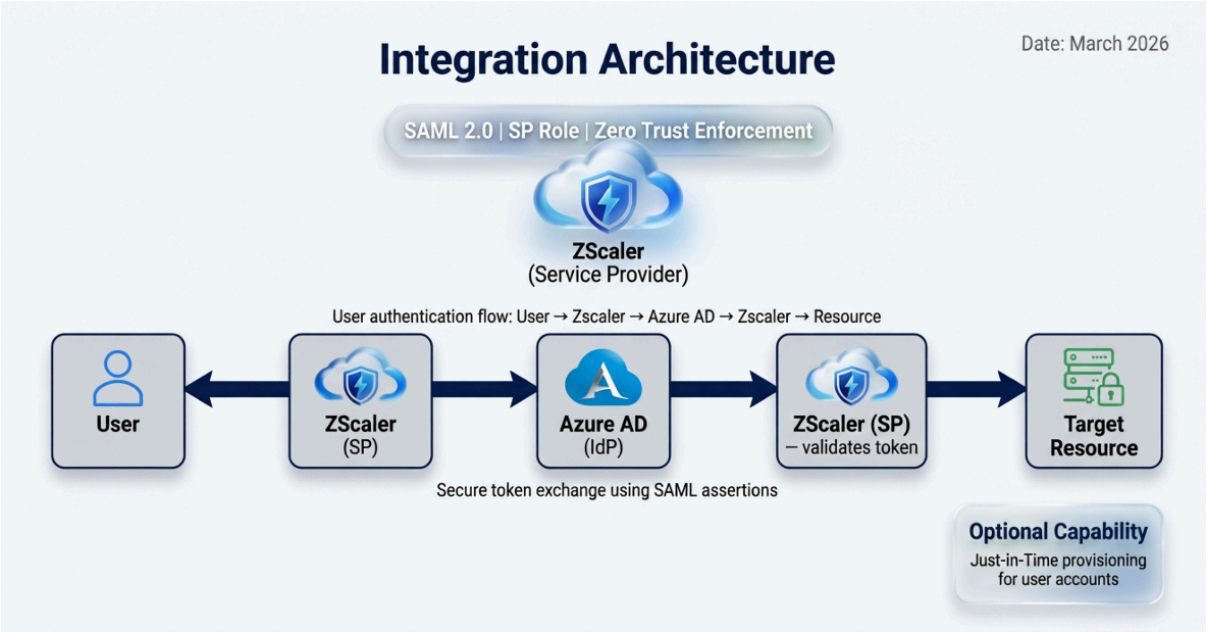
system type is (eg: a printer, router, general-purpose computer, etc).

Business Impact: - It allows for the identification of the remote system type, such as a printer,

router, or general-purpose computer, based on the remote operating system. While this doesn't

pose a direct security threat, it offers valuable insights for network administrators to better

understand and classify the devices in their network. This information aids in network



Conclusion

✅ *Conclusion:* (link unavailable) is a deliberately vulnerable web application designed for security testing

and training, offering a safe environment to practice identifying and exploiting common web vulnerabilities like SQL injection, XSS, and authentication bypass.

Summary and Next Steps

Date: March 2026

Key Summary Points

- "Integration of Zscazer with Azure AD enables secure, seamless access"
- "Leverages existing identity infrastructure for Zero Trust enforcement"
- "Key success factors: proper configuration, testing, and ongoing management"
- Recommended next steps: expand to additional IdPs, enable advanced policies, schedule regular reviews"

Strategic Roadmap Ahead

- "Expand IdP ecosystem: integrate Okta, Ping Identity, and custom SAML providers"
- Enable advanced Zero Trust policies: device posture checks, adaptive risk scoring, session timeout controls"
- Institutionalize governance: quarterly review cycles, audit log retention, and policy versioning"

From integration to institutionalization — building resilient, scalable, and auditable Zero Trust access.

Report

- **The SOC cycle refers to the process**

Tittle :-Integration: SCIM Provisioning Configuration

Implementing SCIM provisioning between Okta and Zscaler automates user and group synchronization for consistent identity management. In the Okta Admin Console, navigate to the Zscaler application created earlier and select the "Provisioning" tab. Click "Configure API Integration" and check "Enable API integration."
Enter the SCIM connector base URL from your Zscaler Admin Portal under Administration > Authentication

> SCIM Configuration, typically https://<tenant>.zscloud.net/scim. Enter the API Token from the same Zscaler configuration page and click "Test API Credentials" to validate connectivity.

Under "Provisioning to App," configure the following settings based on your requirements:
"Create Users" enabled for automatic account creation, "Update User Attributes" enabled for profile synchronization, and "Deactivate Users" enabled for automatic deprovisioning.
Configure the "Push Profile" settings to ensure user attributes including firstName, lastName, email, and displayName are synchronized.
Under "Push Groups," enable group push to Zscaler for policy-based access control, selecting specific groups

to synchronize. Configure attribute mappings by expanding "Attribute Mappings" and reviewing how Okta profile attributes map to Zscaler user schema, making adjustments as needed for custom attributes. Set the provisioning frequency under "Settings," typically every few hours for incremental synchronization. Import existing users and groups by clicking "Import" and selecting which users to assign to the application. Test provisioning by creating a test user in Okta, assigning them to the Zscaler application, and verifying automatic creation in Zscaler. Validate deprovisioning by removing the test user assignment and confirming the user is deactivated in Zscaler. Monitor the provisioning logs for errors and adjust mappings as necessary to ensure

clean data synchronization.
• On-Premises AD Integration: ZAB Deployment

- **Soc :SOC (Security Operations Center)**
- **A Security Operations Center (SOC) is a centralized team that monitors and protects an organization's IT infrastructure from cyber threats. The SOC team continuously analyzes security alerts, logs, and network traffic to detect suspicious activities. They use different security tools such as SIEM, firewalls, and endpoint protection systems to identify attacks and respond quickly. The main goal of a SOC is to prevent data breaches, detect threats early, and ensure the organization's systems remain secure. In companies using cloud security**

platforms like Zscaler, SOC teams monitor user activity and network traffic through the Zscaler platform to identify potential threats

- **SOC Cycle followed by the Security Operations Center to detect and respond to security incidents. The cycle usually includes several stages: monitoring, detection, investigation, response, and recovery. First, security systems monitor network activity continuously. If any suspicious behavior is detected, alerts are generated. Security analysts then investigate the alert to determine whether it is a real threat. If it is confirmed as a security incident, the SOC team takes action to contain and eliminate the threat. Finally, they review the incident and improve**

security controls to prevent similar attacks in the future.

- Siem
- SIEM (Security Information and Event Management)
- SIEM is a cybersecurity technology used to collect, analyze, and manage security logs from different systems in an organization. It helps security teams detect unusual behavior or possible cyber attacks by analyzing large amounts of data in real time. SIEM tools gather logs from servers, network devices, applications, and security systems. These logs are then analyzed to identify patterns that indicate security threats. SIEM also generates alerts for security analysts when suspicious activity is detected. Many organizations integrate SIEM solutions with cloud security platforms

like Zscaler to improve visibility and strengthen their security monitoring capabilities.

- **Siem Cycle**
- **The SIEM cycle describes how security information flows through the SIEM system. It starts with data collection, where logs are gathered from various devices and applications. The next step is data normalization and correlation, where the system organizes the data and identifies relationships between events. After this, the SIEM analyzes the data to detect possible threats or anomalies. If a potential security issue is detected, the system generates an alert for security analysts. Finally, the security team investigates the alert and takes action to resolve the issue. This cycle helps organizations continuously**

monitor and improve their cybersecurity posture.

- **MISP (Malware Information Sharing Platform)**

- **MISP (Malware Information Sharing Platform) is an open-source threat intelligence platform used to share information about cyber threats and attacks. It allows organizations, security researchers, and government agencies to collaborate by sharing data related to malware, vulnerabilities, and attack patterns. The information shared in MISP includes indicators of compromise (IOCs) such as IP addresses, domain names, and file hashes that are linked to cyber attacks. By sharing this information, organizations can quickly detect and prevent similar attacks in their own networks. MISP plays an important**

role in improving global cybersecurity collaboration.

- **Your College Network Information**

- **A college network is the system that connects computers, servers, internet services, and devices within the campus. It allows students, faculty, and staff to access educational resources, online learning platforms, and internet services. The network usually includes routers, switches, Wi-Fi access points, and security systems such as firewalls. Network administrators manage the system to ensure secure and reliable connectivity across the campus. Security measures are implemented to protect the network from cyber threats, unauthorized access, and data breaches. Monitoring tools may also be**

used to track network usage and maintain system performance.

- **Deploying SOC in Our College**

- **To deploy a Security Operations Center (SOC) in our college, we need a centralized system that continuously monitors the college network for security threats. The SOC would collect logs and security data from servers, Wi-Fi networks, firewalls, and student systems. These logs can be analyzed using a SIEM tool such as IBM QRadar. Security analysts or the IT team would monitor alerts and investigate suspicious activities such as unauthorized login attempts or malware infections. The SOC would also maintain policies for access control, data protection, and incident response. By implementing SOC in the**

college network, we can ensure better protection of student data, faculty information, and institutional systems.

- **Threat Intelligence**

- Threat Intelligence refers to collecting and analyzing information about potential cyber threats to prevent attacks. It includes data about malware, phishing domains, malicious IP addresses, and attack techniques used by hackers. Threat intelligence helps security teams understand how attackers operate and how to defend against them. Platforms like MISP allow organizations to share threat information with others. In a college environment, threat intelligence can help the IT team identify harmful websites, detect malware activity in the

network, and prevent phishing attacks targeting students and staff.

- **Incident Response**

- **Incident Response is the process of identifying, managing, and recovering from cybersecurity incidents. When a security issue such as malware infection, data breach, or unauthorized access occurs, the SOC team follows a structured response process. The main steps include detection, analysis, containment, eradication, recovery, and review. For example, if a student's system in the college network is infected with malware, the SOC team would isolate the device, remove the threat, and restore normal operations. Incident response helps reduce damage, recover**

systems quickly, and prevent similar attacks in the future.

- **QRadar & Understanding the Tool**

- IBM QRadar is a Security Information and Event Management (SIEM) tool used by organizations to monitor and analyze security events across their networks. QRadar collects log data from various sources such as servers, firewalls, applications, and network devices. It then analyzes this data using correlation rules and threat intelligence to detect suspicious activity. The tool provides dashboards, alerts, and reports that help security analysts investigate potential threats. In a college SOC environment, QRadar can help monitor student network activity, detect unusual login

attempts, and identify possible cyber attacks in real time.

- **1: What I Understand from Web Application Testing**

- **Web application testing is the process of checking a website or web application for security vulnerabilities, performance issues, and functional errors. It helps ensure that the application works correctly and is protected from cyber attacks such as SQL injection, cross-site scripting (XSS), and authentication bypass. During testing, security professionals analyze the application's login pages, forms, input fields, and server responses to find weaknesses that attackers could exploit. The main goal of web application testing is to improve the security, reliability, and**

performance of the web application before it is used by users.

- **What I Understand from the Nessus Report**

- **The Nessus report provides a detailed analysis of vulnerabilities found in a system or network during a security scan. It shows information about security risks such as outdated software, misconfigured services, weak passwords, and known vulnerabilities. The report usually categorizes issues into different severity levels such as critical, high, medium, and low. Security teams use this report to understand which vulnerabilities are most dangerous and need immediate attention. By reviewing the Nessus report, administrators can apply patches, update software, and fix**

configuration issues to improve the overall security of the system.

- **3: What I Understand from SOC / SIEM / QRadar Dashboard**

- **The SOC, SIEM, and QRadar dashboard helps security teams monitor and analyze security events happening in a network in real time. The dashboard collects logs and alerts from different systems such as servers, firewalls, and applications. It displays important information like suspicious login attempts, unusual network activity, malware alerts, and potential security threats. Tools like IBM QRadar help security analysts detect patterns of attacks and respond quickly to incidents. By analyzing the dashboard, the SOC team can investigate alerts, identify threats, and**

take action to protect the organization's network and data.

- **Future Scope :-**

- **1: Future Scope of Web Application Testing**

- **The future scope of web application testing is very large because most businesses and services are now moving to online platforms. As more websites and web applications are developed, the need to test them for security and performance will continue to grow. Web application testing helps identify vulnerabilities such as SQL injection, cross-site scripting, and authentication issues before attackers can exploit them. In the future, advanced technologies like automation and artificial intelligence will be used to improve testing speed and accuracy. Therefore, web**

application testing will remain an important field in cybersecurity and software development.

- **2: Future Scope of the Testing Process**

- **The testing process will become more advanced and automated in the future. Organizations will increasingly use automated tools and continuous testing methods to identify vulnerabilities quickly during software development. Security testing will also be integrated with DevOps practices, making security checks a part of the development lifecycle. This approach helps developers fix issues early and release secure applications faster. As cyber threats continue to evolve, the testing process will play a critical role in ensuring that systems, applications,**

and networks remain secure and reliable.

- **3: Future Scope of SOC / SIEM**

- **The future scope of Security Operations Centers (SOC) and SIEM systems is expanding as organizations require continuous monitoring and protection from cyber threats. SOC teams use SIEM tools to analyze logs, detect suspicious activities, and respond to security incidents in real time. In the future, SOC operations will rely more on automation, machine learning, and advanced threat intelligence to detect attacks faster and reduce manual effort. Tools like IBM QRadar will continue to evolve with better analytics and threat detection capabilities. As cyber attacks increase globally, SOC and SIEM will play a**

crucial role in maintaining strong cybersecurity for organizations.

- **Topics explored :-Data Collection and Aggregation, Standardization and Normalisation, Enrichment and Analysis,**
- **Sharing and Distribution, Integration with Security Tools, Customization and Flexibility,**
- **Automation and Orchestration, Community Involvement, Incident Response Support, Threat**
- **Intelligence Feeds, Soc and Siem**
- **Tools explored: -Nmap, Metasploit, Nessus, Kali Linux, OWASP ZAP, Burp Suite**
- **Conclusion: -**
-

- **In conclusion, exploring the realm of AI for web security using IBM QRadar has been an**
- **insightful journey through various stages.**
- **In Stage 1, understanding web application testing unveiled the critical importance of assessing**
- **vulnerabilities and ensuring the security of web-based systems. This foundational knowledge**
- **served as a cornerstone for comprehending the subsequent stages.**
- **Stage 2 delved into the intricacies of Nessus reports, emphasising the significance of detailed**
- **vulnerability assessments. Analysing these reports provided valuable insights into potential**

- threats, enabling informed decision-making for robust security measures.
- Stage 3 The replacement of the legacy VPN architecture with a cloud-native Zscaler Zero Trust
- solution marks a pivotal transformation in the organization's security posture. By shifting from a
- network-centric to an application-centric model, this project successfully eliminates the
- expanded attack surface inherent in publicly exposed VPN concentrators and completely
- eradicates the risk of lateral movement. The implementation of Zscaler Private Access (ZPA)
- ensures that users are connected only to specific applications after rigorous identity and device

- **verification, rendering the internal network invisible. This modernization not only fortifies**
- **defenses against sophisticated cyber threats but also delivers a superior, low-latency experience**
- **for the hybrid workforce, establishing a future-ready security foundation..**
- **Considering the future scope, Stage 1 illuminated the evolving landscape of web application**
- **testing. With advancements in AI, there is a promising avenue for more sophisticated testing**
- **methodologies, ensuring even higher levels of security for web applications.**
- **Stage 2 highlighted the future trajectory of the testing process, indicating a shift towards more**

- **automation and integration of AI-driven tools. This evolution promises quicker, more accurate**
- **vulnerability assessments, enhancing overall cybersecurity postures.**
-
- **Stage 3 The integration of Zscaler with enterprise Identity Providers successfully establishes a**
- **unified identity framework that replaces legacy VPN architectures with a modern Zero Trust**
- **security model. This project delivers seamless Single Sign-On capabilities across all Zscaler**
- **services while enforcing consistent security policies including Multi-Factor Authentication and**
- **conditional access based on user identity and context. Automated user provisioning via SCIM**

- **significantly reduces administrative overhead by eliminating manual account management and**
- **ensuring immediate deprovisioning when users leave the organization. The implementation of**
- **identity-based micro-segmentation effectively prevents lateral movement by connecting users to**
- **specific applications rather than the entire network. By leveraging industry-standard protocols**
- **including SAML, OIDC, and LDAP, the integration preserves existing investments in identity**
- **infrastructure while enabling cloud-delivered security. User experience is transformed through**
- **frictionless authentication and reduced latency from Zscaler's global cloud footprint. Security**

- **posture is enhanced through real-time policy enforcement and comprehensive audit logging of**
- **all access attempts. This integration lays a robust foundation for future identity-centric security**